

Hardware CWE™ Special Interest Group (SIG)

Chair: Bob Heinemann (MITRE)

Co-Chair: “Manna” Parbati Kumar Manna (Intel)

MITRE Team: Steve Christey Coley, Alec Summers

MITRE

April 17, 2026



Agenda

REMINDER: This meeting is being recorded.

1	RTL WG Update	Bob H	10 min
2	Commonly Confused CWEs	Jason Oberg	30 min



Housekeeping

- **Schedule:**
 - **Next Meeting May 15:**
 - **Meeting is now the third Friday each month**
 - **12:30 – 1:30 PM EST (16:30 – 17:30 UTC)**
 - **Microsoft Teams**
- **Contact: cwe@mitre.org**
- **Mailing List: hw-cwe-special-interest-group-sig-list@mitre.org**
- **Minutes from previous meetings available on our GitHub site:**
 - <https://github.com/CWE-CAPEC/hw-cwe-sig>



Announcements

- **4.20 release planned for some time in April**
- **CWE Content Development Repository (CDR) is now fully public.**
 - Enables the broader community to view, track, and contribute to entries submissions.
 - Content suggestions begin with the **CWE Submission Form**:
 - <https://cwe.mitre.org/community/submissions/overview.html>
 - CDR can be accessed here:
 - <https://github.com/CWE-CAPEC/CWE-Content-Development-Repository/>



RTL WG Updates

- **The RTL Ad-Hoc Working Group met on March 9 and March 30 and continues to make progress.**
- **Group's key concerns have been consolidated and reframed in CWE-centric terms.**
- **A proposal has been developed to address several of these concerns, resulting in an early draft weakness covering simulation/synthesis mismatches.**
- **Discussion has broadened to include:**
 - RTL Bad coding practices
 - Simulation / synthesis mismatches
 - Buggy EDA Tool Optimizations
 - Certain RTL Behaviors
 - Design Decisions / Semantic Differences
 - RTL / HW Mismatches

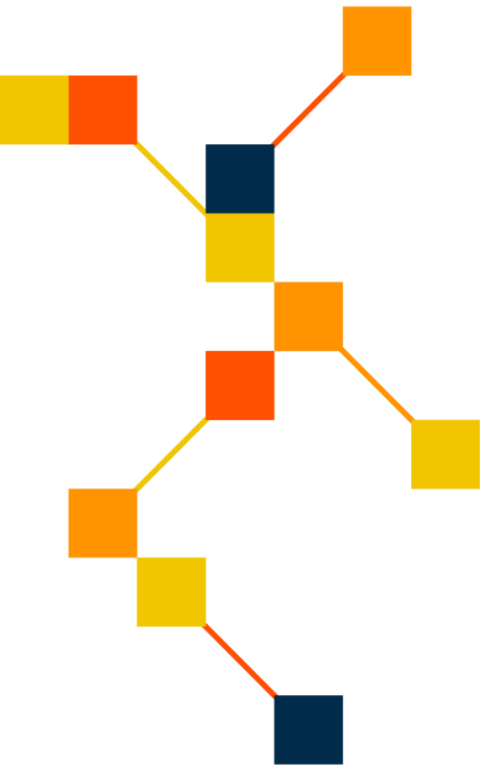


Commonly Confused HW CWEs

Jason Oberg



CWE is sponsored by U.S. Department of Homeland Security (DHS) Cybersecurity and Infrastructure Security Agency (CISA). Copyright © 1999–2026, The MITRE Corporation. CWE and the CWE logo are trademarks of The MITRE Corporation.



Confused/Similar CWEs

HW CWE SIG

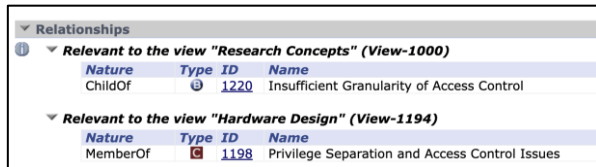
Jason Oberg

April 16th, 2026

ARTERIS 

Introduction

- **Background:** Through a recent third-party IP (3PIP) assurance project, we have reviewed HW CWEs in extensive detail and identified several overlaps
- **Source of Confusion:** The root cause for many CWEs ended up being interpreted to be the same, which resulted in re-use of verification data for multiple CWEs
- **Recommendation:** Possible improvements to the *Relationship* entries to clarify these similarities



Relationships			
Relevant to the view "Research Concepts" (View-1000)			
Nature	Type	ID	Name
ChildOf	ⓘ	1220	Insufficient Granularity of Access Control
Relevant to the view "Hardware Design" (View-1194)			
Nature	Type	ID	Name
MemberOf	ⓘ	1198	Privilege Separation and Access Control Issues

Relationship section of CWEs for context

Summary of Related CWEs

CWE	Related CWEs	Details on Similarities
1220	1262, 1299, 1222	All related to access control
1299	1262	Both related to access control of an asset, with one being a specific instance of the other
1303	1421	Shared microarchitecture state/microarchitecture side channels
1420*	1421, 1422, 1423	1420 is a "catch-all" for transient execution weaknesses (this was by design)
1272	1258, 1239	Data zeroization/clearing
1240	1431, 325	Implementation of cryptographic primitives

*Skipping detailed discussion on CWE-1420 because the similarity is known and by design

CWE-1220: Insufficient Granularity of Access Control

- CWE-1220 address a broad class of access control concerns
- **Similar CWEs:**
 - CWE-1262: Improper Access Control for Register Interface
 - Access control weaknesses specific to a register
 - CWE-1299: Missing Protection Mechanism for Alternate Hardware Interface
 - Access control specific to different interfaces (i.e. policy applies from software but not from AXI)
 - CWE-1222: Insufficient Granularity of Address Regions Protected by Register Locks
 - Related to being unable to modify a register lock
- **Recommendation:**
 - Make all *ChildOf* of CWE-1220
 - CWE-1222 is already a child of CWE-1220

CWE-1299: Missing Protection Mechanism for Alternate Hardware Interface

- CWE-1299 addresses access control via different interfaces (e.g. policy applies from software but not from AXI)
- **Similar CWEs:**
 - CWE-1262: Improper Access Control for Register Interface
 - CWE-1299 can apply to a register, resulting in the analysis for CWE-1299 for a register to be the like the analysis for CWE-1262
- **Recommendation:**
 - Create a *PeerOf* relationship between CWE-1262 and CWE-1299

CWE-1303: Non-Transparent Sharing of Microarchitectural Resources

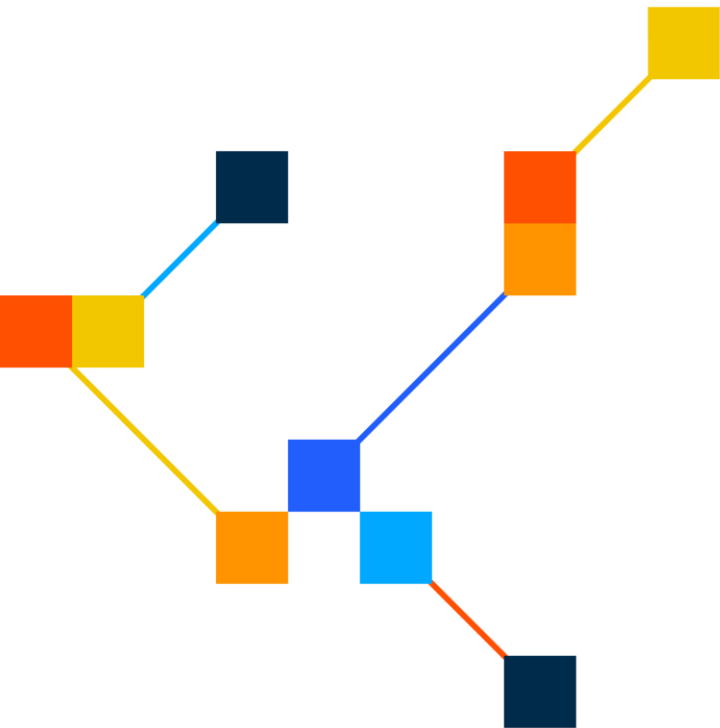
- CWE-1303 address concerns about sharing hardware resources across context in general
- **Similar CWEs:**
 - CWE-1421: Exposure of Sensitive Information in Shared Microarchitectural Structures during Transient Execution
 - Address shared state specifically during transient instruction execution
 - There are several use cases we have observed where shared state occurs outside of the context of transient execution
 - **Examples:**
 - Single-root input/output virtualization (SR-IOV) where PCIe hardware is shared across VMs (NICs, etc.)
 - SoC chip interconnect
- **Recommendation:**
 - Add *PeerOf* or *CanAlsoBe* relationship between CWE-1303 and CWE-1421

CWE-1272: Sensitive Information Uncleared Before Debug/Power State Transition

- CWE-1272 is related to not clearing data when switching debug or power states
- **Similar CWEs:**
 - CWE-1258: Exposure of Sensitive System Information Due to Uncleared Debug Information
 - Specific to not clearing information when switching into debug
 - CWE-1239: Improper Zeroization of Hardware Register
 - Specific to not clearing a register
- **Recommendation:**
 - Make CWE-1258 a *ChildOf* CWE-1272
 - CWE-1258 addresses debug and CWE-1272 address both power modes and debug
 - Add CWE-1239 a *CanAlsoBe* relationship to both CWE-1272 and CWE-1258
 - The asset not being properly cleared/zeroized can be a register

CWE-1240: Use of a Cryptographic Primitive with a Risky Implementation

- CWE-1240 addresses using non-standard crypto or making out-of-spec deviations from standard during implementation
- **Similar CWEs:**
 - CWE-1431: Driving Intermediate Cryptographic State/Results to Hardware Module Outputs
 - Addresses an implementation flaw where intermediate state leaks out
 - CWE-325: Missing Cryptographic Step
 - Address implementation flaw where an important stage of the algorithm is skipped
- **Recommendations:**
 - Make CWE-1431 a *ChildOf* CWE-325
 - CWE-1240 is already a child of CWE-325
 - Make CWE-1431 a *PeerOf* CWE-1420
 - Intermediate state leakage is a risky crypto implementation



ARTERIS 

Thank You

Arteris, Inc. All rights reserved worldwide. Arteris, Arteris IP, the Arteris IP logo, and the other Arteris marks found at <https://www.arteris.com/trademarks> are trademarks or registered trademarks of Arteris, Inc. or its subsidiaries. All other trademarks are the property of their respective owners.

Next Meeting (May 15)

CWE@MITRE.ORG

- **Mailing List:** hw-cwe-special-interest-group-sig-list@mitre.org
 - **NOTE:** All mailing list items are archived publicly at:
 - <https://www.mail-archive.com/hw-cwe-special-interest-group-sig-list@mitre.org/>
- **What would members of this body like to see for the next HW SIG agenda?**
- **Questions, Requests to present? Please let us know.**



Backup



CWE is sponsored by U.S. Department of Homeland Security (DHS) Cybersecurity and Infrastructure Security Agency (CISA).
Copyright © 1999–2026, The MITRE Corporation. CWE and the CWE logo are trademarks of The MITRE Corporation.